



FINANCIAL INFRASTRUCTURE SECURITY

Preston-Check

Enterprise Security Audit Suite v2.0

The Most Comprehensive Security Audit for Financial Platforms

82 check categories, 200+ individual tests, mapped to 6 compliance frameworks. Built from real attack forensics, regulatory requirements, and fintech-specific patterns that no other tool covers. Now with Continuous Defense — real-time threat detection and automated response.

82

CHECK CATEGORIES

200+

INDIVIDUAL TESTS

6

COMPLIANCE FRAMEWORKS

2

RUN MODES

Built from real attack forensics. Named after Preston Braswell, a hacker who created 5+ fake accounts, bypassed 2FA, ran 21,201 automated session polling calls at 1-2 second intervals, and probed for race conditions on a production fintech platform. Every check in this tool is derived from a real vulnerability discovered during that incident and subsequent security audits.

What Makes Preston-Check Different

Finance-Native

Checks for BigDecimal enforcement, rounding modes, double-spend prevention, crypto AML screening, Fireblocks co-signer integration — things generic security tools don't know about.

Attack-Tested

Every check maps to a real attack pattern from forensic analysis of 12.3M log lines. Not theoretical — proven against actual hacker behavior.

6 Compliance Frameworks

Every check mapped to PCI-DSS v4.0, SOC 2, ISO 27001, OWASP API Top 10, NIST CSF 2.0, and CIS Controls v8. 92% PCI-DSS coverage, 100% OWASP API.

Continuous Defense

Real-time threat detection engine: brute force, structuring, layering, dormant reactivation. Graduated response: LOG → THROTTLE → CHALLENGE → HOLD → FREEZE → ALERT. All fail-safe.

Self-Healing with Guardrails

Automated threat response with four-level guardrails: per-rule caps, cooldown timers, confidence thresholds, and human-in-the-loop for irreversible actions. The system can hold and block but never release or approve.

Virtuous Cycle

Self-improving loop: diagnose → compare → learn (3 loops) → propose → approve → fix → verify. Score can only go up, never regress.

Portal Integration

Full Ops Portal UI: score progression, cycle history, individual item approval, threat detection dashboard, rule configuration, deploy button.

Portable & Reusable

Single config.yml per project. Runs on any fintech codebase (Java, TypeScript, Python, Go). Deploy to CI/CD in 5 minutes.

56 Check Categories Across 10 Themes

1. Core Security (P-01 to P-10) — From the Preston Attack

P-01 Hardcoded Secrets

API keys, passwords, AWS keys in source

P-02 2FA Bypass

Code paths that skip authentication

P-03 Info Leakage

Exception messages in API responses

P-04 Rate Limiting

Endpoints without request throttling

P-05 Idempotency

Webhook replay and double-spend protection

P-06 Session Security

IP binding, TTL, session kill capability

P-07 Blacklist

Registration/KYC blacklist enforcement

P-08 Input Validation

SQL injection, command injection

P-09 Audit Trail

DB triggers, append-only ledger

P-10 Live Attacks

Real-time brute force, polling detection

2. Platform Security (P-11 to P-20)

P-11 TLS/Encryption

P-12 Financial Guards

P-13 Auth Enforcement

P-14 Dependency Security

P-15 CORS/CSRF

P-16 Error Handling

P-17 Secure Random

P-18 Data Privacy

P-19 API Versioning

P-20 Deploy Safety

3. Compliance & Regulatory (P-21 to P-24)

P-21 PCI-DSS Card Data

Raw PAN detection, tokenization

P-22 AML Monitoring

CTR thresholds, structuring, SAR

P-23 KYC Document Security

S3 encryption, file validation

P-24 Data Retention

GDPR erasure, Redis TTL

4. Infrastructure (P-25 to P-28) + 5. API Security (P-29 to P-34)

P-25 AWS IAM Hygiene

P-27 TLS Certificate (Live)

P-29 Webhook Signatures

P-31 BOLA (OWASP #1)

P-33 Resource Limits

P-26 Network Exposure

P-28 WAF & DDoS

P-30 HMAC Integrity

P-32 Mass Assignment

P-34 SSRF Prevention

6. Data Protection (P-35 to P-37) + 7. Operations (P-38 to P-40) + 8. Supply Chain (P-41 to P-43)

P-35 DB Encryption

P-37 Backup & DR

P-39 Alerting

P-41 Dependency Pinning

P-43 Container Security

P-36 Key Management

P-38 Security Logging

P-40 Incident Response

P-42 CI/CD Security

9. Mobile & Frontend (P-44 to P-49)

P-44 Flutter Security

P-46 Webhook Ordering

P-48 React Frontend

P-45 Mobile Network

P-47 Reconciliation

P-49 Git History Secrets

10. Finance-Specific Gold Standard (P-50 to P-56)

P-50 Transaction Integrity

BigDecimal, rounding, division safety

P-52 Timing Attacks

Constant-time comparison for secrets

P-54 API Key Management

Expiration, scoping, rotation

P-56 Multi-Signature

Dual approval, Fireblocks co-signer

P-51 Privilege Escalation

Unguarded role/permission mutations

P-53 Account Lifecycle

Locking, email change verification

P-55 Crypto Address

Validation, whitelisting, AML screening

11. Compliance Gap Coverage (P-57 to P-64)

P-57 Business Logic Abuse

OWASP API6 — bot detection, bulk guards

P-59 Security Policies

P-58 Vulnerability Scans

SAST/DAST evidence, scan reports

P-60 Email Security

IR plan, DR plan, security policy docs	SPF/DKIM/DMARC, injection
P-61 Privacy & Consent GDPR, DSAR, data portability	P-62 Pentest Evidence Reports, remediation tracking
P-63 Supply Chain SBOM, dependency locking, vendor assessment	P-64 Recovery Testing DR docs, backup config, health endpoints

12. Finance-Specific Extended Suite (P-65 to P-82) — THE DIFFERENTIATOR

P-65 Transaction Velocity Structuring detection, cooling periods	P-66 Dormant Accounts Reactivation, step-up auth, login anomaly
P-67 Cross-Account Money mule, layering, beneficiary changes	P-68 Fee Manipulation Negative fees, client-side bypass, centralization
P-69 Exchange Rate Safety Stale rates, bounds, spread limits, rate lock	P-70 Settlement Finality No deletion, no status rewind, append-only
P-71 Beneficial Ownership UBO tracking, entity KYC	P-72 Sanctions Screening OFAC, PEP, country restrictions
P-73 Transaction Limits Per-tx, rolling, atomic enforcement	P-74 Proof of Reserves Reconciliation, overdraft, double-entry
P-75 Audit Immutability Triggers, append-only, integrity, retention	P-76 Payment State Machine Valid transitions, terminal states, expiration
P-77 Withdrawal Controls Limits, whitelist, cooldown, 2FA, manual review	P-78 Ledger Consistency Atomic balance, drift detection, orphans
P-79 Regulatory Reporting CTR, SAR, regulatory data export	P-80 Event Sourcing History tables, point-in-time, data lineage
P-81 Financial Input Guards Overflow, negative, NaN, precision, zero-amount	P-82 Continuous Defense Real-time monitoring, auto-response, self-healing

Compliance Framework Coverage

92% PCI-DSS v4.0 10 of 12 requirements automated	85% SOC 2 Type II 5 Trust Services Criteria covered
70% ISO 27001:2022 All technological controls, org gaps noted	100% OWASP API Top 10 All 10 risks covered
80% NIST CSF 2.0 Protect, Detect, Respond fully covered	78% CIS Controls v8 14 of 18 control groups automated

Preston-Check Enterprise Security Suite v3.0
© 2026 Bloxcross. All rights reserved.
Contact: security@bloxcross.com

bloxcross.com